SADI ISO 27001	**POLÍTICA DE SEGURIDAD** Política General de Seguridad de la Información	**Código:** POL-SGSI-001 **Versión:** 2.0 **Fecha:** 22/09/2026

1. OBJETIVO

Establecer el compromiso de la dirección de Organización Demo S.A.S. con la protección de la confidencialidad, la integridad y la disponibilidad de la información, definiendo el marco de referencia para el establecimiento de objetivos de seguridad y para el cumplimiento de los requisitos legales, reglamentarios y contractuales aplicables, conforme a ISO/IEC 27001:2022.

2. ALCANCE

Aplica a toda la información que la organización crea, recibe, procesa, almacena o transmite, en cualquier soporte, y a todo el personal vinculado, contratistas, practicantes y proveedores con acceso a los activos de información. Cubre la sede principal, la bodega y los servicios de tecnología tercerizados, según el alcance del SGSI documentado en el acta ACT-SGSI-001.

3. RESPONSABLES

La Gerencia General aprueba la política y asigna los recursos. El Oficial de Seguridad de la Información mantiene el SGSI, coordina la apreciación de riesgos y reporta el desempeño. La Coordinación de TI implementa los controles técnicos. Gestión Humana gestiona los controles de personas. Los dueños de proceso responden por la información de su ámbito. Todo el personal debe cumplir la política y reportar los eventos de seguridad.

4. MARCO LEGAL Y NORMATIVO

ISO/IEC 27001:2022 - Sistemas de gestión de seguridad de la información. ISO/IEC 27005:2022 - Gestión de riesgos de seguridad de la información. Ley 1273 de 2009 - Protección de la información y de los datos. Ley 1581 de 2012 y Decreto 1377 de 2013 - Protección de datos personales. CONPES 3854 de 2016 - Política Nacional de Seguridad Digital. CONPES 3995 de 2020 - Política Nacional de Confianza y Seguridad Digital.

5. LINEAMIENTOS

1. La información es un activo de la organización y debe protegerse con controles proporcionales al riesgo, valorado con la matriz de probabilidad e impacto de 5x5 adoptada del

estándar ISO/IEC 27005.
2. El acceso a la información se concede bajo los principios de mínimo privilegio y necesidad de conocer, y se revisa al menos trimestralmente.
3. Todo incidente o evento de seguridad debe reportarse por el canal definido en el procedimiento PR-SGSI-001, dentro de las cuatro horas siguientes a su detección.
4. La información se clasifica como pública, interna o confidencial, y se etiqueta y maneja conforme a esa clasificación.
5. Los riesgos con nivel igual o superior a 9 requieren un plan de tratamiento formal con responsable y plazo, y no pueden darse por cerrados sin evidencia de la eficacia de las acciones.
6. Los proveedores con acceso a información de la organización deben suscribir acuerdos de confidencialidad y cláusulas de seguridad, y son objeto de seguimiento periodico.
7. El incumplimiento de esta política se trata conforme al proceso disciplinario previsto en el reglamento interno de trabajo.
8. Esta política se revisa anualmente y cuando ocurran cambios significativos en el contexto, en los riesgos o en los requisitos legales.
9. Los servicios en la nube que traten información de la organización deben contratarse a nombre de la empresa, con acuerdo de nivel de servicio, ubicación de los datos declarada y procedimiento de salida documentado. Queda prohibido el uso de cuentas personales de almacenamiento para información de trabajo.

6. CONTROL DE VERSIONES

Versión	Fecha	Cambio	Responsable
2.0	22/09/2026	Se incorpora el numeral 9 sobre el uso de servicios en la nube y se actualiza el numeral 2 con la periodicidad trimestral de revisión de accesos, conforme a los hallazgos de la auditoría de seguimiento del Tema Tecnológico.	Liliana Vargas

7. APROBACIÓN

ELABORÓ	REVISÓ	APROBÓ
Liliana Vargas	Julián Castaño	Dirección General
Oficial de Seguridad de la Información	Auditor Interno Líder	Gerente General
Firma	Firma	Firma